

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

You bought a cage

**Isolation asks:
can it touch the host?**

**Release asks:
should we believe
these bytes?**

Those two questions got collapsed.

The control is green. You still lost.

checker.py	hash unchanged
expected.json	worker-written
CI / merge check	PASS

GET /admin (no cookie)	401 required
shipped	200

You did not accept a bad parser. You accepted a policy rewrite.

Recorded Linux isolation run + factory

We verified a locked door. We merged an open one.

Merge from the live path after a swap Open /admin

Hash the path, hash it again The path can move

Evaluate and merge the frozen object Same digest

Approval for A applied to B Denied

A green check on the wrong bytes is still a 200 with no cookie.

Recorded Linux isolation run + factory

The process never left

```
identity    we handed it another project's token
files       the mount did exactly what we configured
release     the allowed host was never the question
```

Containment held. The grant did the work of an escape.

Recorded Linux isolation run + factory

Stop taking testimony from the box

**The candidate is a subject.
It is not a witness.**

Freeze the bytes. Compare off the worker. Merge that object.

A green harness is a log line. It is not a 401.

Recorded Linux isolation run + factory

Same ticket. Different witness.

Locked /admin, frozen Merged. No cookie is 401.

Open /admin Rejected

Worker PASS file Ignored

Worker expected.json Ignored

Swap after freeze Denied

Recorded Linux isolation run + factory

If the writer is also the witness

Ask

Whose identity?

Which files, including tomorrow's?

Which recipient, which contents?

Who says /admin is locked?

If the answer is the box, you lost

You handed it over

Snapshots and forks keep the crime

The allowed host was the wrong question

You do not have acceptance. You have a diary.

CONTAINMENT IS NOT ATTESTATION

Who gave this process the authority?

github.com/zozo123/nyc-talk

Yossi Eliaz

Appendix / Reproduction

```
make factory      # freeze, judge, gate; no cloud
make demo         # educational Linux isolation lab
make deck         # evidence check + PDF
```

29 lab checks passed, 6 factory checks passed.

Appendix / Limits

A class identification, not a vendor bug.

Deterministic scripts. Five cases prove five cases.

In-sandbox grading is known. File-integrity of the checker can still pass.

Timeouts are no approval, not a successful defense.

Appendix / Primary references

Anthropic reward hacking

Process-exit graders are known

SLSA verifying artifacts

A valid statement can still name the wrong bytes

pytest plugins

Loading workspace code is documented. Trusting it as acceptance is ours.